

ЛР 4

Провести симуляцию XSS-атаки

Цель

1. найти CVE за 2021 год, содержащие XSS в компонентах, написанных на php.
2. на предоставленном стенде провести XSS-атаку и убедиться в выполнении JS-скрипта

Описание/Пошаговая инструкция выполнения домашнего задания

Часть I.

Необходимо среди CVE за 2021 год найти те, которые содержат XSS в компонентах, написанных на php. Для двух из них описать, для чего конкретный компонент используется, какой функционал предоставляет. Также необходимо посчитать общее количество CVE за 2021 год.

Ответ

текстовый файл.

5 баллов

Часть II.

1. Скачать уязвимый образ с `docker.hub`, выполнив команду из консоли

```
docker pull ket9/otus-devsecops-xss
```

2. Запустить образ

```
docker run -d -p 8080:80 ket9/otus-devsecops-xss:latest
```

3. Зайти на

```
http://localhost:8080/
```

4. Провести XSS-атаку на приложение и убедиться, что ваш скрипт выполняется в контексте браузера клиента.

Материалы к занятию

В материалах к занятию также будет доступен файл `homework-emu.txt`, где будет описана атака, и к которому вы сможете обратиться в случае сложностей с практической частью дз.

Что должно быть в ответе на ДЗ

Ответом на дз будет текстовый файл, содержащий:

1. ход ваших рассуждений, что пробовали делать, какой был ответ приложения, какие выводы вы из этого делали.
2. тип найденной уязвимости
3. меры предотвращения (напишите подробно, каких символов хотите избегать, что будете для этого делать.)

5 баллов

Критерии оценки

Часть I:

Условие	Баллы
для одной CVE указано назначение уязвимого компонента	1 балл
для двух	3 балла
для двух + посчитано количество	5 баллов

тут неважно, ошибется студент в подсчете или нет, главное, что он должен убедиться, что даже за 2021 год такая уже вдоль и поперек изученная уязвимость встречается очень много раз

Часть II.

Условие	Баллы
описан ход рассуждений	2 балла
тип	2+1 балла
описан ход рассуждений, тип, меры предотвращения	2+1+2 баллов

Итог

Минимальный проходной балл - 7 баллов

Максимальное количество баллов за ДЗ - 10